GIÁO TRÌNH ĐÀO TẠO LÃNH ĐẠO CÔNG NHÂN

CẤP TRUNG CẤP · BUỔI 5

AN TOÀN SỐ

CYBERSECURITY

cho nhà hoạt động nghiệp đoàn

THÔNG TIN BUỔI HỌC

Thời lượng: 90 phút (dạy trực tuyến)

Hình thức: Online; hướng dẫn công cụ kết hợp thực hành thiết lập ngay trên thiết bị

Điều kiện: Học viên đã hoàn thành cấp Sơ cấp và Trung cấp Buổi 1–4

Vị trí: Buổi 5 cấp Trung cấp — nối tiếp tư duy an toàn (Sơ cấp Buổi 3)

Tinh thần của buổi học: *An toàn số không phải là chuyện kỹ thuật cao siêu, mà là những thói quen đơn giản, làm đều đặn, để bảo vệ chính mình và những người mình quý mến. Công cụ chỉ là một lớp; kỷ luật của con người mới là lớp bảo vệ quan trọng nhất. Buổi này trang bị một bộ công cụ và thói quen thực dụng, có thể thiết lập ngay hôm nay.*

Lưu ý cập nhật: *Khuyến nghị công cụ trong tài liệu cập nhật đến năm 2026. Thế giới an toàn số thay đổi nhanh — giảng viên nên kiểm tra thông tin mới nhất (ví dụ từ Electronic Frontier Foundation, Access Now, Front Line Defenders) trước mỗi khóa.*

MỤC LỤC

MỤC LỤC 2
PHẦN A · GIÁO ÁN (KẾ HOẠCH GIẢNG DẠY) 3
1. Mục tiêu bài học 3
2. Chuẩn bị 3
3. Tiến trình 90 phút 3
4. Lưu ý an toàn khi dạy 4
5. Đánh giá & bài tập về nhà 4
PHẦN B · TÀI LIỆU LÝ THUYẾT 5
Mở đầu: An toàn số là bảo vệ con người 5
1. Mô hình hóa nguy cơ & nguyên tắc nền 5
2. Liên lạc an toàn 5
3. Mật khẩu & xác thực hai lớp 5
4. Nhiều danh tính & phân tách 6
5. Lưu trữ, mã hóa & bảo vệ thiết bị 6
6. Duyệt web ẩn danh & VPN 6
7. Nhận diện lừa đảo (phishing) 7
8. Mười nguyên tắc vàng 7
Tổng kết: 3 điều cần nhớ 8
PHẦN C · PHỤ LỤC 9
Phụ lục 1 · Bảng công cụ khuyến nghị (2026) 9
Phụ lục 2 · Checklist thiết lập an toàn số 9
Phụ lục 3 · Thẻ “10 nguyên tắc vàng” 9
Phụ lục 4 · Bảng thuật ngữ 9

PHẦN A · GIÁO ÁN (KẾ HOẠCH GIẢNG DẠY)

1. Mục tiêu bài học

Sau buổi học, học viên có thể:

Về kiến thức

- Giải thích "mô hình hóa nguy cơ" và nguyên tắc "công cụ chỉ là một lớp, con người là chính".
- Kể tên các công cụ an toàn nên dùng cho từng nhu cầu: liên lạc, mật khẩu, xác thực, lưu trữ, duyệt web.
- Nhận diện các dấu hiệu lừa đảo (phishing) phổ biến.

Về kỹ năng

- Thiết lập ít nhất một ứng dụng nhắn tin an toàn, một trình quản lý mật khẩu và xác thực hai lớp.
- Bật mã hóa ổ cứng và khóa màn hình mạnh trên thiết bị của mình.
- Áp dụng "10 nguyên tắc vàng" vào thói quen hằng ngày.

Về thái độ

- Coi an toàn số là thói quen bền bỉ, không phải nỗi sợ hay việc làm một lần.
- Cân bằng giữa an toàn và tiện dụng theo mức độ nguy cơ thật của mình.

2. Chuẩn bị

Đối tượng	Cần chuẩn bị
Giảng viên	• Slide trình chiếu (bộ đi kèm giáo án này). • Bảng công cụ khuyến nghị (Phụ lục 1) và "10 nguyên tắc vàng" (Phụ lục 3). • Cập nhật tình trạng các công cụ trước khóa (nguồn: EFF, Access Now). • Chuẩn bị vài ví dụ tin nhắn/email lừa đảo (ẩn danh) để luyện nhận diện.
Học viên	• Mang điện thoại (và laptop nếu có) để thực hành thiết lập ngay. • Kết nối mạng ổn định để tải và cài ứng dụng.
Công cụ	• Nền tảng họp có breakout và poll ẩn danh. • Bật phòng chờ, đặt mật khẩu; không ghi hình buổi học.

3. Tiến trình 90 phút

Thời gian	Nội dung	Hoạt động & phương pháp
0–8' (8')	**Mở đầu & kết nối**	• Nhắc: tư duy an toàn (Sơ cấp Buổi 3) nay áp vào thế giới số. • Nêu thông điệp lớn: công cụ + kỷ luật, không phải sợ hãi.
8–15' (7')	**Khởi động**	• Poll: "Bạn đang dùng cách nào để bảo vệ tài khoản của mình?" — dẫn vào bài.
15–25' (10')	**Mô hình hóa nguy cơ & nguyên tắc nền**	• Bốn câu hỏi mô hình hóa nguy cơ; nguyên tắc con người là lớp bảo vệ chính.
25–37' (12')	**Liên lạc an toàn**	• Signal / SimpleX / Session; luôn bật E2E + tự xóa; tránh Telegram, Zalo, Messenger.
37–50' (13')	**Mật khẩu & xác thực hai lớp**	• Trình quản lý mật khẩu; passphrase; 2FA (app mã nguồn mở, khóa phần cứng); tránh SMS.

Thời gian	Nội dung	Hoạt động & phương pháp
50–60' (10')	**Danh tính, lưu trữ & bảo vệ thiết bị**	• Tách danh tính; Proton Drive; mã hóa ổ cứng; Lockdown Mode; khóa màn hình.
60–70' (10')	**Duyệt web ẩn danh & VPN**	• DuckDuckGo, Brave, Tor Browser, Mullvad; VPN an toàn và cảnh báo VPN miễn phí.
70–80' (10')	**Nhận diện lừa đảo (phishing)**	• Dấu hiệu; nguyên tắc không bấm link lạ; luyện nhận diện vài ví dụ.
80–90' (10')	**10 nguyên tắc vàng, thực hành & tổng kết**	• Đi qua 10 nguyên tắc; học viên thiết lập ngay 1–2 công cụ; giao bài; hẹn Buổi 6.

4. Lưu ý an toàn khi dạy

• **Phòng vệ, hợp pháp:** toàn bộ nội dung là kỹ năng tự bảo vệ khỏi giám sát và trả đũa khi thực hiện quyền hợp pháp — không phải để tấn công hệ thống hay che giấu hành vi vi phạm pháp luật.

• **Cân bằng, không gây sợ:** nhấn mạnh an toàn số là thói quen khả thi, không phải gánh nặng hay nỗi hoang mang.

• **Thực hành thật:** khuyến khích học viên thiết lập ngay tại lớp; nhưng không ai bị ép chia sẻ thông tin cá nhân hay tài khoản thật.

5. Đánh giá & bài tập về nhà

Đánh giá nhanh trong buổi

- Học viên thiết lập được ít nhất một công cụ mới ngay tại lớp.
- Poll cuối giờ: “Một nguyên tắc vàng bạn sẽ áp dụng ngay tuần này.”

Bài tập về nhà

- Hoàn tất bảng “Checklist thiết lập an toàn số” (Phụ lục 2) cho thiết bị của mình.
- Cài một trình quản lý mật khẩu và chuyển ít nhất 5 tài khoản quan trọng sang mật khẩu mạnh + 2FA.

PHẦN B · TÀI LIỆU LÝ THUYẾT

Mở đầu: An toàn số là bảo vệ con người

Điện thoại và máy tính chứa gần như toàn bộ đời sống của chúng ta — danh bạ, tin nhắn, hình ảnh, tài khoản. Với một người hoạt động, đó cũng là nơi rủi ro nhất nếu bị giám sát. Nhưng tin tốt là: **phần lớn rủi ro số đều phòng được bằng những thói quen đơn giản**. Buổi này không biến bạn thành chuyên gia máy tính; nó trang bị một bộ công cụ và thói quen thực dụng để bảo vệ chính mình và những người mình quý mến.

1. Mô hình hóa nguy cơ & nguyên tắc nền

Không ai bảo vệ được mọi thứ khỏi mọi nguy cơ. Trước khi chọn công cụ, hãy trả lời bốn câu hỏi để biết mình cần gì:

Câu hỏi	Ý nghĩa
Tôi muốn bảo vệ điều gì?	Tài sản cần bảo vệ: danh bạ, tin nhắn, danh tính, tài liệu.
Bảo vệ khỏi ai?	Ai là "đối thủ": kẻ tò mò, người báo lại, bên có nhiều nguồn lực.
Hậu quả nếu lộ là gì?	Mất việc, bị gây khó dễ, ảnh hưởng người khác — mức độ nghiêm trọng.
Tôi sẵn sàng bỏ ra bao nhiêu công?	Cân bằng an toàn và tiện dụng theo nguy cơ thật của mình.

> **Nguyên tắc quan trọng nhất — đọc trước mọi công cụ**
> Công cụ chỉ là MỘT lớp bảo vệ. Ứng dụng tốt nhất cũng vô ích nếu bạn bấm vào một đường link lừa đảo, dùng mật khẩu yếu, hay kể chuyện nhạy cảm với người không đáng tin. **Kỷ luật của con người mới là lớp bảo vệ quan trọng nhất.** Và: dữ liệu nhạy cảm ít lưu càng tốt — tốt nhất là giữ trong đầu.

2. Liên lạc an toàn

Điểm mấu chốt là "mã hóa đầu-cuối" (E2E): chỉ người gửi và người nhận đọc được, ngay cả bên vận hành cũng không. Luôn ưu tiên các ứng dụng E2E mặc định, và **luôn bật tin nhắn tự xóa (tối đa một tuần)**.

Ứng dụng	Đặc điểm	Vai trò
Signal	Mã hóa đầu-cuối mặc định mọi tin nhắn/cuộc gọi/nhóm; lưu rất ít dữ liệu. Cần số điện thoại.	Lựa chọn mặc định, phù hợp phần lớn nhu cầu.
SimpleX	Không có định danh người dùng, không cần số điện thoại — kết nối qua liên kết dùng một lần.	Khi cần ẩn danh cao nhất.
Session	Không cần số điện thoại; mã định danh ngẫu nhiên; ẩn IP qua định tuyến nhiều lớp.	Khi cần ẩn danh, không gắn số điện thoại.
Telegram, Zalo, Messenger	**KHÔNG dùng cho việc nhạy cảm.** Telegram không mã hóa đầu-cuối mặc định; Zalo/Messenger coi như bên vận hành đọc được.	Chỉ nói chuyện chung chung, vô thưởng vô phạt.

Nhắc lại từ cấp Sơ cấp: *việc nhạy cảm nhất nên gặp trực tiếp, nơi riêng tư — không thiết bị nào an toàn tuyệt đối.*

3. Mật khẩu & xác thực hai lớp

3.1. Trình quản lý mật khẩu

Không thể nhớ hàng chục mật khẩu mạnh khác nhau — hãy để một trình quản lý mật khẩu làm việc đó. Bạn chỉ cần nhớ MỘT mật khẩu chính thật mạnh.

- **Nên dùng:** Proton Pass, Bitwarden (mã nguồn mở, có bản miễn phí tốt). Nếu muốn hoàn toàn ngoại tuyến: KeePassXC.

- **Mật khẩu chính: chỉ giữ trong đầu.**
- **Mỗi tài khoản một mật khẩu riêng, dài, ngẫu nhiên:** để lộ một nơi không kéo theo mọi nơi.

3.2. Xác thực hai lớp (2FA)

2FA thêm một "lớp khóa" thứ hai ngoài mật khẩu. Nhưng không phải cách 2FA nào cũng an toàn như nhau:

Cách 2FA	Đánh giá
Khóa phần cứng (YubiKey / FIDO2)	Mạnh nhất — chống được cả lừa đảo (phishing). Nên dùng cho tài khoản quan trọng nhất.
App mã nguồn mở: Aegis (Android), Ente Auth (đa nền tảng)	Rất tốt: mã hóa cục bộ hoặc E2E, không phụ thuộc tài khoản của hãng lớn.
Proton / Google / Microsoft Authenticator	Dùng được, nhưng lưu ý: **đồng bộ đám mây của Google KHÔNG mã hóa đầu-cuối** (Google giữ khóa); Microsoft thu thập dữ liệu vận hành.
Tin nhắn SMS	Yếu nhất — dễ bị chiếm số điện thoại (SIM swapping). Tránh nếu có lựa chọn khác.

> **Ba việc phải làm với 2FA**
>
> 1. Bật 2FA cho mọi tài khoản quan trọng (email, mạng xã hội, trình quản lý mật khẩu).
> 2. Lưu "mã khôi phục" (recovery codes) ở nơi an toàn — để không bị khóa khi mất điện thoại.
> 3. Nhớ: ngay cả 2FA qua app cũng có thể bị lừa qua trang đăng nhập giả; khóa phần cứng chống được điều này.

4. Nhiều danh tính & phân tách

Khi cần, hãy tách **danh tính hoạt động** khỏi **danh tính cá nhân**. Điều này giới hạn thiệt hại nếu một danh tính bị lộ (nối lại nguyên tắc "ngăn cách/một đầu mối" ở Buổi 2).

- Dùng email riêng, tên hiển thị riêng cho việc hoạt động; không trộn với tài khoản cá nhân.
- Không dùng lại ảnh đại diện, số điện thoại, hay thói quen dễ nhận ra giữa các danh tính.
- Giữ mỗi danh tính "sạch": không đăng nhập lẫn lộn, không liên kết chéo.

5. Lưu trữ, mã hóa & bảo vệ thiết bị

- **Tài liệu nhạy cảm:** lưu trên dịch vụ mã hóa đầu-cuối như Proton Drive; hoặc mã hóa tệp trước khi lưu. Ít lưu càng tốt — tốt nhất là trong đầu.
- **Mã hóa ổ cứng:** bật BitLocker (Windows) hoặc FileVault (macOS). Khi máy bị mất/lấy cắp, dữ liệu vẫn không đọc được.
- **Khóa màn hình mạnh:** dùng mã PIN 6 số trở lên hoặc passphrase, không chỉ vân tay/khuôn mặt. Lưu ý: sinh trắc học đôi khi dễ bị ép mở hơn một mã khóa.
- **Lockdown Mode:** trên iPhone/iPad và máy Mac, bật Chế độ Khóa (Lockdown Mode) nếu bạn thuộc nhóm nguy cơ cao — nó giảm mạnh bề mặt bị tấn công.
- **Cập nhật thường xuyên:** cài bản cập nhật hệ điều hành và ứng dụng sớm — đây là một trong những việc bảo vệ hiệu quả nhất mà ít người làm đều.

6. Duyệt web ẩn danh & VPN

6.1. Trình duyệt

Nhu cầu	Nên dùng
Duyệt web hằng ngày trên điện thoại	DuckDuckGo (chặn theo dõi, dễ xóa dữ liệu chỉ bằng một nút).

Nhu cầu	Nên dùng
Duyệt web hằng ngày trên laptop	Brave hoặc LibreWolf (chặn quảng cáo/theo dõi mặc định).
Việc thật sự nhạy cảm, cần ẩn danh	Tor Browser thật (ẩn IP qua nhiều lớp).
Chống nhận dạng, không cần mạng Tor	Mullvad Browser (dùng cùng một VPN).

> **Lưu ý cập nhật về "Brave + Tor"**
> Cửa sổ riêng tư "với Tor" của Brave tiện lợi, nhưng KHÔNG mạnh bằng Tor Browser thật về ẩn danh và chống nhận dạng. Việc thật sự nhạy cảm nên dùng chính Tor Browser. Ngoài ra: đừng đăng nhập vào tài khoản định danh bạn khi đang dùng Tor — làm vậy sẽ mất tác dụng ẩn danh.

6.2. VPN

VPN che địa chỉ IP và giấu lưu lượng khỏi mạng bạn đang dùng. Nhưng **VPN không phải phép màu**: nó không khiến bạn ẩn danh tuyệt đối và không bảo vệ một thiết bị đã bị xâm nhập.

- **Miễn phí đáng tin nhất:** ProtonVPN (bản miễn phí) — được kiểm toán, không ghi log, không giới hạn dữ liệu, được nhà báo và nhà hoạt động tin dùng.
- **Cảnh báo:** PHẦN LỚN VPN miễn phí khác nguy hiểm — họ bán dữ liệu duyệt web của bạn. TunnelBear miễn phí chỉ cho khoảng 2GB/tháng.
- **Mạnh nhất (nếu có điều kiện trả phí):** Mullvad hoặc ProtonVPN trả phí — không yêu cầu thông tin cá nhân, không log.

7. Nhận diện lừa đảo (phishing)

Đa số vụ mất tài khoản KHÔNG đến từ "hack" cao siêu, mà từ **lừa đảo (phishing)**: một tin nhắn/email giả khiến bạn tự nguyện gõ mật khẩu vào trang giả, hay bấm vào link độc. Đây là mắt xích yếu nhất — và cũng dễ phòng nhất.

Dấu hiệu thường gặp

- Tạo cảm giác khẩn cấp: "tài khoản sắp bị khóa", "xác minh ngay".
- Đường link lạ, địa chỉ gần giống thật nhưng sai một chút; hoặc link rút gọn.
- Yêu cầu đăng nhập, nhập mật khẩu hoặc mã 2FA qua link.
- Người gửi giả danh người quen, cấp trên, hoặc một dịch vụ bạn dùng.

Ba quy tắc chống phishing

1. **Không bấm link lạ.** Tự gõ địa chỉ trang web vào trình duyệt thay vì bấm link trong tin nhắn/email.
2. **Xác minh qua kênh khác.** Nếu "cấp trên" hay "ngân hàng" nhắn gấp, gọi/hỏi lại qua kênh đã biết trước khi làm gì.
3. **Không ai cần mật khẩu của bạn.** Dịch vụ thật không bao giờ hỏi mật khẩu/mã 2FA qua link. Khóa phần cứng giúp chống cả phishing.

8. Mười nguyên tắc vàng

1. Cập nhật hệ điều hành, ứng dụng và thiết bị thường xuyên.
2. Mỗi tài khoản một mật khẩu dài, duy nhất; dùng trình quản lý mật khẩu.
3. Bật xác thực hai lớp; ưu tiên app mã nguồn mở hoặc khóa phần cứng, tránh SMS.
4. Chỉ trao đổi việc nhạy cảm qua Signal / SimpleX / Session, luôn bật tự xóa.
5. Không bấm link lạ; xác minh trước khi tin (chống phishing).
6. Mã hóa ổ cứng và đặt khóa màn hình mạnh.
7. Bật Lockdown Mode nếu bạn thuộc nhóm nguy cơ cao.

8. Lưu tài liệu nhạy cảm ở nơi mã hóa (Proton Drive); tốt nhất là giữ trong đầu.
9. Tách danh tính hoạt động khỏi danh tính cá nhân.
10. Nhớ: công cụ chỉ là một lớp — kỷ luật của con người mới là lớp bảo vệ chính.

Tổng kết: 3 điều cần nhớ

1. Biết mình cần bảo vệ gì, khỏi ai (mô hình hóa nguy cơ) rồi mới chọn công cụ cho vừa sức.
2. Bộ công cụ nền: Signal/SimpleX/Session · trình quản lý mật khẩu + 2FA · mã hóa ổ cứng · Proton Drive · trình duyệt riêng tư + VPN đáng tin.
3. Công cụ chỉ là một lớp — cập nhật, cảnh giác phishing, và kỷ luật con người mới giữ bạn an toàn.

PHẦN C · PHỤ LỤC

Phụ lục 1 · Bảng công cụ khuyến nghị (2026)

Nhu cầu	Nên dùng	Tránh / thận trọng
Nhắn tin, gọi	Signal, SimpleX, Session (bật tự xóa)	Telegram (nhóm), Zalo, Messenger cho việc nhạy cảm
Quản lý mật khẩu	Proton Pass, Bitwarden, KeePassXC	Tái sử dụng mật khẩu; lưu trong trình duyệt
Xác thực hai lớp	Aegis, Ente Auth, khóa phần cứng (YubiKey)	2FA qua SMS
Lưu tài liệu nhạy cảm	Proton Drive; hoặc mã hóa trước khi lưu	Kho lưu trữ không mã hóa
Duyệt web (điện thoại)	DuckDuckGo	Trình duyệt mặc định không riêng tư
Duyệt web (laptop)	Brave/LibreWolf; Tor Browser cho việc nhạy cảm	Coi "Brave + Tor" bằng Tor Browser thật
VPN	ProtonVPN (miễn phí đáng tin); Mullvad (trả phí)	Phần lớn VPN miễn phí khác (bán dữ liệu)

Phụ lục 2 · Checklist thiết lập an toàn số

Việc cần làm	Xong?
Cập nhật hệ điều hành & ứng dụng lên bản mới nhất	
Cài trình quản lý mật khẩu; đặt một passphrase chính mạnh	
Bật 2FA cho email và các tài khoản quan trọng; lưu mã khôi phục	
Cài Signal (hoặc SimpleX/Session); bật tin nhắn tự xóa	
Bật mã hóa ổ cứng (BitLocker/FileVault)	
Đặt khóa màn hình mạnh (PIN 6+ số hoặc passphrase)	
Cài trình duyệt riêng tư; cài ProtonVPN nếu cần	
Bật Lockdown Mode (nếu nguy cơ cao)	

Phụ lục 3 · Thẻ "10 nguyên tắc vàng"

> **1. Cập nhật thường xuyên · 2. Mật khẩu dài, duy nhất + trình quản lý · 3. 2FA (app/khóa phần cứng, tránh SMS)**
>
> **4. Việc nhạy cảm chỉ qua Signal/SimpleX/Session + tự xóa · 5. Không bấm link lạ · 6. Mã hóa ổ cứng + khóa mạnh**
>
> **7. Lockdown Mode nếu nguy cơ cao · 8. Tài liệu nhạy cảm mã hóa / trong đầu · 9. Tách danh tính · 10. Con người là lớp bảo vệ chính**

Phụ lục 4 · Bảng thuật ngữ

Thuật ngữ	Giải thích ngắn gọn
Mã hóa đầu-cuối (E2E)	Chỉ người gửi và người nhận đọc được; bên vận hành cũng không.
Xác thực hai lớp (2FA)	Lớp khóa thứ hai ngoài mật khẩu (mã app, khóa phần cứng...).
Phishing (lừa đảo)	Tin nhắn/trang giả khiến bạn tự nộp mật khẩu hoặc bấm link độc.

Thuật ngữ	Giải thích ngắn gọn
Passphrase	Mật khẩu dạng chuỗi nhiều từ, dài, dễ nhớ nhưng khó đoán.
Mô hình hóa nguy cơ	Xác định bảo vệ gì, khỏi ai, hậu quả, và công sức bỏ ra.
Lockdown Mode	Chế độ khóa của Apple, giảm mạnh bề mặt bị tấn công cho người nguy cơ cao.

Tài liệu này phục vụ mục đích giáo dục về tự bảo vệ an toàn số cho người thực hiện các hoạt động hợp pháp về quyền lao động. Khuyến nghị công cụ có tính thời điểm; cần cập nhật theo hướng dẫn mới nhất của các tổ chức uy tín (EFF, Access Now, Front Line Defenders).